

Enhanced Attack Report

Goofy Guineapig

Generated on 2025-10-07

Disclaimer

This report has been generated automatically and should be used for informational purposes only. To generate this report, Large Language Models (LLMs) were used to analyze the provided data. This technology is not perfect and may generate incorrect or misleading results. The results should be reviewed by a human expert before taking any action based on the information provided.

Definitions

Pre-Conditions: Conditions that must be true to execute the attack steps in the milestone.

Post-Conditions: Traces that an attacker leaves behind after executing the attack steps in the milestone.

Attack Steps: Steps that an attacker would take to achieve the goal of the milestone.

MITRE Technique: Techniques from the MITRE ATT&CK; framework that are relevant to the milestone.

STIX

Malware Name: Goofy Guineapig

Malware Description: The Goofy Guineapig loader is a UPX packed, trojanised NSIS Firefox installer. Once extracted, it masquerades as a Google update component. Goofy Guineapig maintains persistence as a Windows service. Goofy Guineapig provides a framework into which additional plugins may be loaded. The backdoor supports multiple communications methods, including HTTP, HTTPS and KCP. The configuration is embedded in the binary, and the configuration for the binary analysed results in command and control communications occurring over HTTPS. Many defence evasion techniques are implemented throughout execution.

Quick Overview

Milestone m1

a1. Create or Modify System Process: Windows Service as used by the malware (T1543.003)

Milestone m2

- a2. Masquerading: Match Legitimate Name or Location as used by the malware (T1036.005)
- a3. Virtualization/Sandbox Evasion: Time Based Evasion as used by the malware (T1497.003)
- a4. Virtualization/Sandbox Evasion: System Checks as used by the malware (T1497.001)
- a5. Virtualization/Sandbox Evasion: User Activity Based Checks as used by the malware (T1497.002)
- a6. Obfuscated Files or Information: Software Packing as used by the malware (T1027)
- a7. Deobfuscate/Decode Files or Information as used by the malware (T1140)
- a8. Hide Artifacts: Hidden Window as used by the malware (T1564.003)
- a9. Indicator Removal on Host: File Deletion as used by the malware (T1070.010)
- a10. Hijack Execution Flow: DLL Side-Loading as used by the malware (T1574.001)
- a11. Process Injection: Process Hollowing as used by the malware (T1055.012)
- a12. Signed Binary Proxy Execution: Rundll32 as used by the malware (T1218.011)

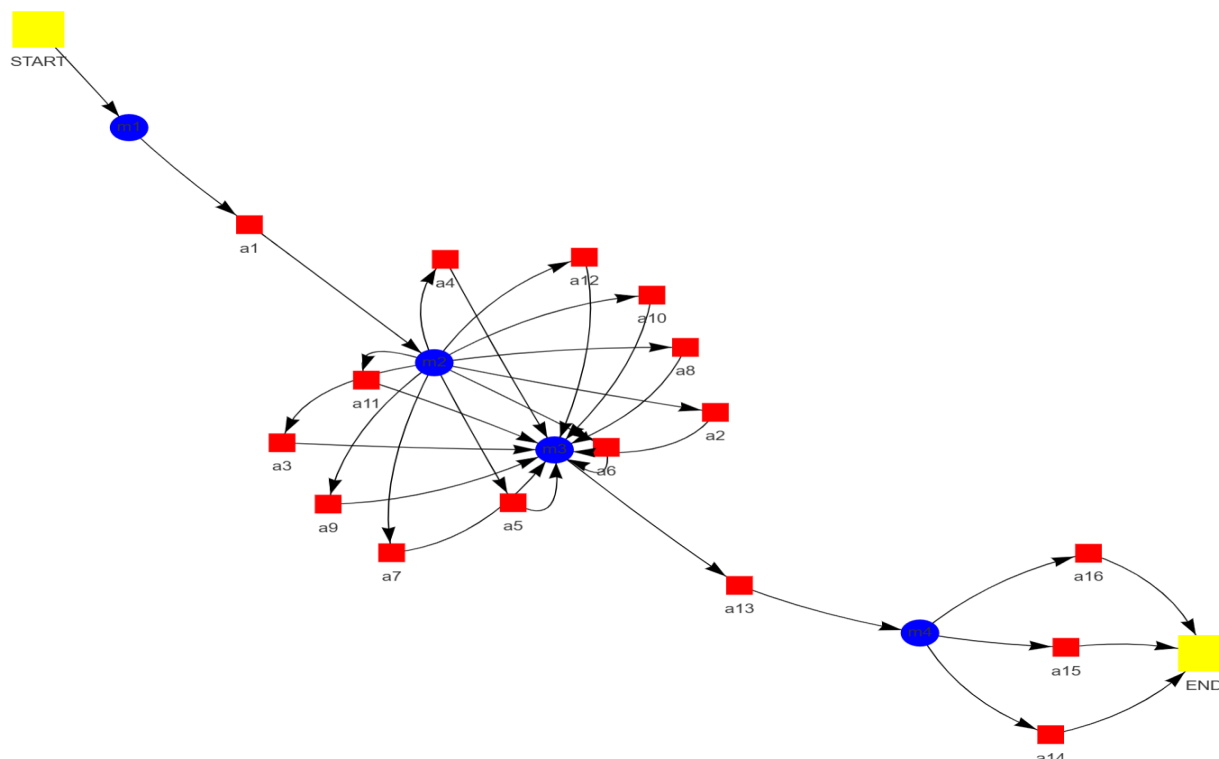
Milestone m3

a13. System Information Discovery as used by the malware (T1049)

Milestone m4

- a14. Application Layer Protocol: Web Protocols as used by the malware (T1071.001)
- a15. Fallback Channels as used by the malware (T1008)
- a16. Non-Standard Port as used by the malware (T1571)

Attack Graph



Milestone *m1*

Attack Step *a1*

=====

Name: Create or Modify System Process: Windows Service as used by the malware

Description: A Windows service is established by the malware designated as "Goofy Guineapig" to ensure persistence within the system. The service, named "GoogleUpdate," is configured with a display name that likely mirrors the service name. The creation and configuration of this service are facilitated through the execution of shellcode originating from a trojanized GoogleUpdate installer. This shellcode leverages the rundll32 command to specify the service parameters, including its name, display name, startup type, and the path to the malware's executable file as the service binary. The elevated privileges inherent in Windows services grant malware access to sensitive system resources and data, while their background operation can render them less conspicuous to security software and users.

Pre-Conditions:

- The malware has successfully infected a target system running Windows.
- The malware can access system files and registry entries related to services.
- A Windows operating system is present.

Post-Conditions:

- Network traffic logs showing communication with attacker-controlled server.
- Potential for further malicious activity on the compromised system.
- System instability and performance degradation.
- New user account created or existing account privileges elevated.
- Data exfiltration to attacker-controlled server.
- Traces of data transfer to external storage devices.
- Modified system registry entries.
- Compromised system with persistent backdoor access.
- Altered system configuration files.
- Hidden files and folders containing malware components.
- Event log entries indicating suspicious activity, such as service creation or process execution.

MITRE Technique

ID: T1543.003

Name: Create or modify system process: windows service

Description: Adversaries may create or modify Windows services to repeatedly execute malicious payloads as part of persistence. When Windows boots up, it starts programs or applications called services that perform background system functions. Windows service configuration information, including the file path to the service's executable or recovery programs/commands, is stored in the Windows Registry.

More info: <https://attack.mitre.org/techniques/T1543/003>

Milestone *m2*

Attack Step *a2*

=====

Name: Masquerading: Match Legitimate Name or Location as used by the malware

Description: The "Goofy Guineapig" malware employs deceptive techniques to circumvent user suspicion during installation. A Trojanized Firefox installer, packaged within an NSIS file, is presented to users as a legitimate software update. Subsequently, upon extraction, the malware further obfuscates its malicious intent by mimicking a Google update component, capitalizing on user trust in established software entities.

Pre-Conditions:

- The malware must have access to a file system.

Post-Conditions:

- Malicious DLLs in memory and/or on disk
- Potential for further malicious activity
- Backdoor access established
- Remote code execution
- Persistence on the system
- New user accounts created
- Modified registry entries
- Data exfiltration
- Altered system files
- System compromise
- Unusual process activity logs
- Network connections to C2 server
- Hidden or encrypted files

MITRE Technique

ID: T1036.005

Name: Masquerading: match legitimate resource name or location

Description: Adversaries may match or approximate the name or location of legitimate files, Registry keys, or other resources when naming/placing them. This is done for the sake of evading defenses and observation.

More info: <https://attack.mitre.org/techniques/T1036/005>

Attack Step *a3*

=====

Name: Virtualization/Sandbox Evasion: Time Based Evasion as used by the malware

Description: The "Goofy Guineapig" malware is characterized by its utilization of a trojanized Firefox installer for initial access. A malicious DLL, designated as "Goopdate.dll," is incorporated into the installer and subsequently loaded by the legitimate "GoogleUpdate.exe" executable. Communication with the command-and-control (C2) server, located at static[.]tcplog[.]com, is established via HTTPS

protocols, employing both GET and POST requests. Persistence mechanisms employed by the malware include process hollowing of "dllhost.exe," the establishment of a scheduled task, and the utilization of rundll32.exe and url.dll for code execution. Sandbox detection is performed by analyzing system time registers. Obfuscation techniques are implemented to hinder analysis by security researchers. Functionality encompasses task execution based on commands received from the C2 server. These tasks may include data exfiltration, system reconnaissance, or other malicious actions. Data exfiltration capabilities enable the malware to steal sensitive information from the victim's system and transmit it to the C2 server. The "Goofy Guineapig" malware presents a significant threat due to its potential for data theft, system compromise, and espionage activities.

Pre-Conditions:

- The malware is running in an environment where time can be measured.

Post-Conditions:

- "temp.bat" file and its remnants.
- Modified Windows registry entries for persistence (service creation).
- "goopdate.dll" file in ProgramData directory.
- Logs containing suspicious activity related to the backdoor and data exfiltration.
- Compromised system with persistent backdoor access.
- Traces of executed commands and processes.
- Potential for further malicious activity on the infected machine.
- Modified system files with malicious code.
- Data exfiltration to C2 server.

MITRE Technique

ID: T1497.003

Name: Virtualization/sandbox evasion: time based evasion

Description: Adversaries may employ various time-based methods to detect and avoid virtualization and analysis environments. This may include enumerating time-based properties, such as uptime or the system clock, as well as the use of timers or other triggers to avoid a virtual machine environment (VME) or sandbox, specifically those that are automated or only operate for a limited amount of time.

More info: <https://attack.mitre.org/techniques/T1497/003>

Attack Step a4

=====

Name: Virtualization/Sandbox Evasion: System Checks as used by the malware

Description: System checks are employed by Goofy Guineapig to potentially evade virtualization/sandbox environments. The malware analyzes system characteristics such as disk size, physical memory size, and the number of logical processors to infer its execution context. Thresholds, derived from typical values observed in real systems and known sandbox configurations, are utilized for comparison against gathered system information. Discrepancies between measured values and predefined thresholds may lead to the malware interpreting its environment as a sandbox or virtualized setting. Subsequent actions taken by Goofy Guineapig, contingent upon its design, could include termination of execution, modification of behavior to a "safe mode," or attempts at deception to circumvent sandbox detection mechanisms.

Pre-Conditions:

- The malware is running.

Post-Conditions:

- System instability and performance degradation.
- Presence of malicious "Goopdate.dll" file in ProgramData directory.
- Data exfiltration to attacker-controlled server.
- Compromised system with persistent malware.
- New batch script ("temp.bat") with remnants of execution commands.
- Network traffic logs showing communication with attacker-controlled server (HTTPS, UDP, TCP).
- Potential for further attacks and lateral movement within the network.
- Modified system files containing backdoor functionality.
- Event log entries indicating suspicious activity and process executions.
- Modified registry entries related to GoogleUpdate.exe.

MITRE Technique

ID: T1497.001

Name: Virtualization/sandbox evasion: system checks

Description: Adversaries may employ various system checks to detect and avoid virtualization and analysis environments. This may include changing behaviors based on the results of checks for the presence of artifacts indicative of a virtual machine environment (VME) or sandbox. If the adversary detects a VME, they may alter their malware to disengage from the victim or conceal the core functions of the implant. They may also search for VME artifacts before dropping secondary or additional payloads. Adversaries may use the information learned from Virtualization/Sandbox Evasion during automated discovery to shape follow-on behaviors.

More info: <https://attack.mitre.org/techniques/T1497/001>

Attack Step a5

=====

Name: Virtualization/Sandbox Evasion: User Activity Based Checks as used by the malware

Description: User activity-based checks are employed to detect sandboxed or virtualized environments by analyzing deviations in user behavior compared to real systems. These checks often focus on unusual process presence, including known debugging tools and virtualization software components. Network traffic patterns, such as restricted access or logged connections, are also scrutinized for anomalies indicative of a sandboxed setup. Furthermore, system calls and API usage are monitored for discrepancies from expected behavior in virtualized environments. Malware such as Goofy Guineapig may implement process monitoring techniques utilizing Windows API functions to enumerate running processes and compare them against known sandbox indicators. Network traffic analysis could be conducted using libraries or APIs like WinPcap to capture and analyze network packets, searching for patterns associated with sandboxes. System call monitoring might involve kernel debugging techniques or interception mechanisms to track system calls made by processes, flagging deviations from typical usage patterns. Upon detection of a sandboxed environment, Goofy Guineapig may halt execution, enter a dormant state, or execute alternate code designed for non-sandboxed systems.

Pre-Conditions:

- The malware can monitor user activity.
- The malware is running.

Post-Conditions:

- Traces of deleted or modified files related to security software or logs.
- Network connections to attacker-controlled IP addresses for data transfer and command execution.
- System instability and performance degradation.
- Data exfiltration to attacker-controlled server.
- Compromised system with persistent backdoor access.
- Log entries indicating suspicious process creation, file modifications, and network activity.
- New files created in temporary directories or system folders containing malicious code (e.g., config.dat, goopdate.dll).
- Potential for further malware infections and lateral movement within the network.
- Modified registry entries related to GoogleUpdate.exe and Goofy Guineapig components.
- Altered system configurations and permissions granting elevated privileges to the malware.

MITRE Technique

ID: T1497.002

Name: Virtualization/sandbox evasion: user activity based checks

Description: Adversaries may employ various user activity checks to detect and avoid virtualization and analysis environments. This may include changing behaviors based on the results of checks for the presence of artifacts indicative of a virtual machine environment (VME) or sandbox. If the adversary detects a VME, they may alter their malware to disengage from the victim or conceal the core functions of the implant. They may also search for VME artifacts before dropping secondary or additional payloads. Adversaries may use the information learned from Virtualization/Sandbox Evasion during automated discovery to shape follow-on behaviors.

More info: <https://attack.mitre.org/techniques/T1497/002>

Attack Step a6

=====

Name: Obfuscated Files or Information: Software Packing as used by the malware

Description: Software packing is employed by Goofy Guineapig to conceal its malicious code within a seemingly benign program shell. This process involves compressing, rearranging, and embedding the original malware code within a shell containing instructions for unpacking upon execution. The packed malware, significantly reduced in size, is disseminated as part of a legitimate-appearing NSIS installer for Firefox. Upon user execution of the installer, the UPX-packed malware is loaded into memory. The shell code then unpacks the original malware code, enabling it to execute and carry out malicious activities. This technique presents challenges for security software and researchers due to its ability to evade detection and analysis by obscuring the true nature of the malware. The dynamic behavior of the unpacked code further complicates traditional signature-based detection methods. Goofy Guineapig utilizes additional obfuscation techniques, including leveraging the trust associated with Firefox updates through file association and employing process hollowing to inject malicious code into legitimate processes for enhanced privilege escalation and evasion.

Pre-Conditions:

- The malware code exists in a form requiring obfuscation.
- A computer system running an operating system compatible with the malware.
- Software packing tools are accessible.
- The malware authors have chosen to employ software packing techniques.

Post-Conditions:

- Potential for further malicious activity on the compromised system.
- Modified Windows registry entries related to the persistence mechanism (service creation).
- Logs indicating suspicious process creations and executions.
- Compromised system with persistent backdoor access.
- Traces of deleted files from original GoogleUpdate.exe and Goopdate.dll paths.
- New files created in unusual locations, potentially containing malware or stolen data.
- Network connections to static[.]tcplog[.]com.
- Altered system files or configurations.
- Data exfiltration to C2 server.

MITRE Technique

ID: T1027

Name: Obfuscated files or information

Description: Adversaries may attempt to make an executable or file difficult to discover or analyze by encrypting, encoding, or otherwise obfuscating its contents on the system or in transit. This is common behavior that can be used across different platforms and the network to evade defenses.

More info: <https://attack.mitre.org/techniques/T1027/>

Attack Step a7

=====

Name: Deobfuscate/Decode Files or Information as used by the malware

Description: Goofy Guinea pig's deobfuscation and decoding processes involve several techniques. Strings are stored on the program's call stack, hindering immediate identification through textual analysis. Obfuscation techniques employed include Single Byte XOR encryption, where each character is combined with a fixed key byte using the XOR operation, and subtraction, which involves subtracting characters from a specific value, resulting in an altered representation of the original string. Deobfuscation necessitates identifying stack-based strings within the malware's code structure. Reverse engineering techniques, utilizing disassemblers and debuggers, are employed to trace the application of XOR or subtraction operations. Key recovery is crucial and may involve pattern analysis, static code examination for hardcoded keys, or dynamic analysis observing memory interactions during execution. Once the key is obtained, it can be applied to the XORed or subtracted characters to recover the original strings.

Pre-Conditions:

- Knowledge of the RC4 encryption key (NZTslkAC6FUDY7FyN).
- A tool capable of performing RC4 decryption.
- The malware utilizes RC4 encryption and Base64 encoding.
- The malware's files or information are accessible.
- A tool capable of performing Base64 decoding.

Post-Conditions:

- Traces of deleted files or processes.
- Altered system settings or configurations.

- New files (e.g., malicious DLLs, configuration files) in ProgramData directory or other locations.
- Modified System Registry entries for persistence.
- Compromised system with persistent backdoor access.
- Logs containing suspicious activity related to process creation, file modifications, and network communication.
- Indicators of compromise (IOCs) matching known Goofy Guineapig artifacts.
- Potential for further malicious activity, including lateral movement and privilege escalation.
- Data exfiltration to C2 server.

MITRE Technique

ID: T1140

Name: Deobfuscate/decode files or information

Description: Adversaries may use Obfuscated Files or Information to hide artifacts of an intrusion from analysis. They may require separate mechanisms to decode or deobfuscate that information depending on how they intend to use it. Methods for doing that include built-in functionality of malware or by using utilities present on the system.

More info: <https://attack.mitre.org/techniques/T1140/>

Attack Step a8

=====

Name: Hide Artifacts: Hidden Window as used by the malware

Description: Process hollowing is employed by the malware designated as "Goofy Guineapig" to conceal its malicious activities. This technique involves the replacement of legitimate code within an existing process with the malware's own payload. The target process selected is dllhost.exe, a standard Windows component responsible for hosting dynamic link libraries (DLLs). The integration of malicious code into dllhost.exe provides several advantages for Goofy Guineapig. Firstly, the legitimacy of dllhost.exe may lead to reduced scrutiny from security software. Secondly, the execution of malware code within the context of dllhost.exe obscures its presence and hinders analysis efforts. In addition to process hollowing, Goofy Guineapig may utilize supplementary techniques to further obfuscate its operations. These techniques could encompass minimizing or concealing the window associated with dllhost.exe, or even the creation of processes devoid of visible windows. The aforementioned tactics present significant challenges for detection mechanisms. Signature-based detection methods, commonly employed by antivirus software, rely on recognizing known malware code patterns. Process hollowing circumvents this approach due to the constant evolution and adaptation of the malicious payload. Behavioral analysis techniques, utilized by more sophisticated security solutions, aim to identify suspicious activity. However, Goofy Guineapig's ability to mimic legitimate processes complicates the differentiation between normal and malicious behavior.

Pre-Conditions:

- The malware possesses the capability to manipulate window properties.
- The malware has successfully executed and is running in the target system.

Post-Conditions:

- Network connections to C2 server (static[.]tjcplog[.]com).
- Altered system configurations.
- Modified or deleted original files.
- Presence of malicious DLLs and executables.

- System instability and performance degradation.
- Log entries indicating suspicious activity.
- Compromised system with persistent backdoor access.
- New files created in various locations (e.g., temp directory, ProgramData).
- Potential for further malicious activity on the infected machine.
- Modified registry entries.
- Unusual process creation patterns.
- Data exfiltration to C2 server.

MITRE Technique

ID: T1564.003

Name: Hide artifacts: hidden window

Description: Adversaries may use hidden windows to conceal malicious activity from the plain sight of users. In some cases, windows that would typically be displayed when an application carries out an operation can be hidden. This may be utilized by system administrators to avoid disrupting user work environments when carrying out administrative tasks.

More info: <https://attack.mitre.org/techniques/T1564/003>

Attack Step a9

=====

Name: Indicator Removal on Host: File Deletion as used by the malware

Description: A comprehensive analysis of the "Goofy Guineapig" malware has been conducted, providing an overview of its functionalities, tactics, and techniques. Key findings include: The malware is disseminated through a Trojanized Firefox installer, deceiving users into executing it. Persistence on compromised systems is achieved by establishing a Windows service, ensuring continued operation across system restarts. Communication with the command-and-control (C2) server is facilitated via HTTPS on non-standard port 4443, employing UDP and raw TCP as fallback options to evade detection. A modular design enables the malware to download and execute plugins for diverse malicious purposes. File deletion activities are observed during the initial stages of infection: Files are initially downloaded to a temporary location. Subsequently, extracted files, including the malicious Goopdate.dll, are relocated to a directory appearing more legitimate. Finally, the original files from the initial download location are deleted, aiming to conceal the malware's presence. The techniques employed by "Goofy Guineapig" align with several tactics and techniques within the MITRE ATT&CK framework: Persistence is achieved through T1543.003 - Create or Modify System Process: Windows Service. Defense Evasion is facilitated by T1036.005 - Masquerading: Match Legitimate Name or Location. Command and Control operations utilize T1071.001 - Application Layer Protocol: Web Protocols, and T1571 - Non-Standard Port. Further analysis could focus on: The specific actions performed by downloaded plugins to determine their malicious intent. Decrypting and analyzing C2 communication traffic to uncover command instructions and data exfiltration methods. Identifying the types of systems targeted by "Goofy Guineapig" and the potential impact on victims.

Pre-Conditions:

- The malware has determined which files to delete as indicators of its presence.
- The malware has successfully infected the target host.

Post-Conditions:

- Potential for further malicious activity on the compromised system.

- Altered system configurations.
- Modified user permissions.
- New files created (e.g., "temp.bat", malicious DLL).
- Data exfiltration to attacker-controlled server.
- Compromised system with persistent backdoor access.
- Presence of obfuscated code in memory or on disk.
- Modified registry entries for persistence.
- Network connections to static[.]tcplog[.]com.
- Log entries indicating process creation and execution of suspicious commands.

MITRE Technique

ID: T1070.010

Name: Indicator removal: relocate malware

Description: Once a payload is delivered, adversaries may reproduce copies of the same malware on the victim system to remove evidence of their presence and/or avoid defenses. Copying malware payloads to new locations may also be combined with File Deletion to cleanup older artifacts.

More info: <https://attack.mitre.org/techniques/T1070/010>

Attack Step a10

=====

Name: Hijack Execution Flow: DLL Side-Loading as used by the malware

Description: The Goofy GuineaPig malware employs DLL side-loading to subvert execution flow. A trojanized Firefox installer, compressed with UPX, is utilized as a deceptive delivery mechanism. The malware loader further simulates a Google update component by creating a hidden process and executing a batch file that ultimately loads the malicious Goopdate.dll. The malware exploits an existing legitimate executable, potentially "GoogleUpdate.exe," leveraging its system trust. Goopdate.dll is injected into the process space of this legitimate executable, enabling the malicious code to execute within a trusted application context and evade detection by security measures. This technique results in hidden execution of the malicious payload within the legitimate process, hindering detection by traditional security tools focused on individual processes. The exploitation of a trusted executable grants Goofy GuineaPig elevated privileges, facilitating actions such as data access or system setting modification that would otherwise be restricted. Detection of this attack necessitates advanced techniques analyzing process behavior and memory content rather than relying solely on signature-based detection methods. Process monitoring for unexpected DLL loading within legitimate processes can aid in identifying malicious injections. Memory analysis examining loaded modules within a process can reveal the presence of unknown or suspicious DLLs. Behavioral analysis observing actions performed by a process after DLL loading can highlight malicious activity.

Pre-Conditions:

- The user account executing the process has sufficient permissions to load libraries.
- A legitimate executable file exists with a known path.
- The malicious DLL is available in a location accessible to the system.
- The target process has the ability to load dynamic libraries.

Post-Conditions:

- Potential for further malicious activity on the compromised system.
- "goopdate.dll" file in ProgramData directory.

- Log files containing suspicious activity.
- Compromised system with persistent malware infection.
- Network connections to static[.]tcplog[.]com.
- Modified registry entries related to the GoogleUpdate service.
- Malicious "GoogleUpdate.exe" service running.
- Presence of backdoor functionality within compromised processes.
- Altered system files or configurations.
- Data exfiltration to C2 server.

MITRE Technique

ID: T1574.001

Name: Hijack execution flow: dll

Description: Adversaries may abuse dynamic-link library files (DLLs) in order to achieve persistence, escalate privileges, and evade defenses. DLLs are libraries that contain code and data that can be simultaneously utilized by multiple programs. While DLLs are not malicious by nature, they can be abused through mechanisms such as side-loading, hijacking search order, and phantom DLL hijacking.

More info: <https://attack.mitre.org/techniques/T1574/001>

Attack Step a11

=====

Name: Process Injection: Process Hollowing as used by the malware

Description: Goofy Guineapig malware is characterized as a backdoor distributed through bundled legitimate Firefox installation files, indicative of social engineering tactics. Its sophistication level is assessed as low, exhibiting deficiencies in coding practices and operational security. Similarities in defense evasion techniques with Jolly Jellyfish malware suggest a potential shared origin. Persistence within target systems is achieved through the establishment of a Windows service mimicking "GoogleUpdate." Process hollowing is employed to inject malicious code into the legitimate dllhost.exe process, obscuring its presence. Communication with the command and control (C2) server static[.]tcplog[.]com is facilitated via HTTPS GET and POST requests. The malware's tactics and techniques align with MITRE ATT&CK; framework entries: T1543.003 for "Create or Modify System Process: Windows Service" under Persistence, and T1036.005 for "Masquerading: Match Legitimate Name or Location" and T1497.003 for "Virtualization/Sandbox Evasion: Time Based" under Defense Evasion. Detection of Goofy Guineapig is facilitated by YARA rules such as "GoofyGuineapig_processtart," which identifies process hollowing behavior, and the detection of a unique command employed by the malware, as detailed in the NCSC report. Recommendations for mitigating the threat posed by Goofy Guineapig include: * Network monitoring to identify suspicious connections to static[.]tcplog[.]com. * Implementation of robust endpoint security solutions with real-time threat detection capabilities. * Utilization of process monitoring tools to detect anomalous process behavior, such as process hollowing. * Regular patching of systems to address vulnerabilities that could be exploited by malware like Goofy Guineapig. * Security awareness training to educate users about social engineering tactics and the importance of verifying software downloads. Understanding the characteristics and behaviors of Goofy Guineapig enables security professionals to implement effective countermeasures for safeguarding their organizations against this threat.

Pre-Conditions:

- The malware possesses the necessary code to perform process hollowing.
- A vulnerable process is running on the target system.
- The malware has the capability to read and modify memory.
- The malware has successfully gained control of the target system.

Post-Conditions:

- New batch script (.bat) file.
- System instability and performance degradation.
- Network connections to C2 server (static IP or domain name).
- Unusual process activity in Task Manager.
- Potential for further malicious activity.
- Modified firewall rules.
- Altered system event logs.
- Compromised system with persistent malware.
- Hidden malicious files in ProgramData directory.
- Logs containing suspicious activity.
- Presence of Goopdate.dll and other malicious binaries.
- Modified registry entries.
- Data exfiltration to C2 server.

MITRE Technique

ID: T1055.012

Name: Process injection: process hollowing

Description: Adversaries may inject malicious code into suspended and hollowed processes in order to evade process-based defenses. Process hollowing is a method of executing arbitrary code in the address space of a separate live process.

More info: <https://attack.mitre.org/techniques/T1055/012>

Attack Step a12

=====

Name: Signed Binary Proxy Execution: Rundll32 as used by the malware

Description: Goofy Guineapig malware is characterized by its backdoor functionality and deployment via Trojanized NSIS installers mimicking legitimate software updates. Persistence on infected systems is achieved through the utilization of Windows services. Communication with the command-and-control (C2) server, located at static[.]jtcplg[.]com, primarily occurs via HTTPS GET and POST requests. Fallback mechanisms employing UDP and direct socket communication are also implemented. The malware exhibits evasion tactics such as sandbox detection and anti-analysis techniques including code obfuscation and error handling to impede analysis efforts. Execution is facilitated through signed binary proxy execution leveraging rundll32.exe and url.dll, exploiting the legitimacy of these system tools. Process hollowing techniques, targeting processes like dllhost.exe, are employed to conceal malicious activity. System information discovery encompasses the collection of data such as hostname, computer name, operating system, and user details, which are subsequently transmitted to the C2 server in obfuscated HTTP headers. Application Layer Protocol utilizes HTTPS over non-standard port 4443 for secure communication with the C2 server. Fallback communication channels, including UDP and direct socket connections, are available if HTTPS is unavailable. The potential impact of Goofy Guineapig malware includes data theft, remote command execution on compromised systems, and establishment of persistent access through its persistence mechanism, ensuring continued access even after system reboots.

Pre-Conditions:

- The Rundll32 executable must be accessible to the malware process.

- A running Windows operating system.
- Network connectivity may be required for downloading or retrieving the malicious DLL.

Post-Conditions:

- Modified system registry entries for persistence.
- Potential for further malicious activity on the compromised system.
- Disk activity logs showing data transfers to/from the compromised system.
- Hidden or renamed malicious files in ProgramData directory.
- Event log entries related to process creation and modification.
- New user account created or existing account privileges elevated.
- Compromised system with persistent malware.
- Modified system files (e.g., DLLs, executables).
- Firewall logs indicating suspicious connections.
- Network traffic logs showing communication with C2 server.
- Data exfiltration to C2 server.

MITRE Technique

ID: T1218.011

Name: System binary proxy execution: rundll32

Description: Adversaries may abuse rundll32.exe to proxy execution of malicious code. Using rundll32.exe, vice executing directly (i.e. Shared Modules), may avoid triggering security tools that may not monitor execution of the rundll32.exe process because of allowlists or false positives from normal operations. Rundll32.exe is commonly associated with executing DLL payloads (ex: rundll32.exe {DLLname, DLLfunction}).

More info: <https://attack.mitre.org/techniques/T1218/011>

Milestone *m3*

Attack Step *a13*

=====

Name: System Information Discovery as used by the malware

Description: System information discovery performed by Goofy GuineaPig malware involves the obfuscation of transmitted data within HTTP header "Authorization" strings. The precise system data points collected by Goofy GuineaPig remain unspecified. However, common data points gathered by malware include computer name, hostname, operating system details, and user information. This collected information is utilized by attackers for targeting specific operating systems and versions to exploit vulnerabilities, facilitating credential theft through potential phishing campaigns, and mapping network structures to identify targets. The security implications of Goofy GuineaPig's system information collection necessitate robust endpoint security measures encompassing real-time monitoring of suspicious network activity, including unusual HTTP requests with encoded data in headers. Network traffic analysis tools are instrumental in detecting anomalies and potential exfiltration of sensitive data. User awareness training regarding phishing attempts and the avoidance of personal information sharing is crucial. Further analysis necessitates access to the malware code for revealing specific data points collected and encoding methods, as well as network traffic capture to elucidate the structure and content of "Authorization" strings transmitted to the command-and-control server.

Pre-Conditions:

- The malware is running on a target system.
- Network connectivity may be required for certain information gathering tasks (e.g., querying external services).
- A running instance of the Goofy GuineaPig malware.
- Access to system APIs such as GetLocalTime.

Post-Conditions:

- Modified firewall rules.
- Traces of deleted files and processes.
- Log entries indicating suspicious activity.
- Altered system files.

MITRE Technique

ID: T1049

Name: System network connections discovery

Description: Adversaries may attempt to get a listing of network connections to or from the compromised system they are currently accessing or from remote systems by querying for information over the network.

More info: <https://attack.mitre.org/techniques/T1049/>

Milestone *m4*

Attack Step *a14*

=====

Name: Application Layer Protocol: Web Protocols as used by the malware

Description: The Goofy GuineaPig malware employs HTTPS for Command and Control (C2) communication. HTTPS, or Hypertext Transfer Protocol Secure, is utilized to encrypt data transfer between the malware and its designated C2 server. This encryption protocol renders it more challenging for security tools to intercept and analyze the exchanged data. The C2 server, remotely controlled by the attackers, serves as the recipient of commands from the malware and the source of instructions relayed back to it. The selection of HTTPS by malicious actors is driven by several factors. Firstly, while seemingly paradoxical, the secure nature of HTTPS obfuscates malware activities from security researchers and antivirus software. Secondly, HTTPS traffic often integrates seamlessly with legitimate web traffic, thereby hindering the identification of malicious connections. Lastly, the perceived trustworthiness associated with websites employing HTTPS can be exploited by attackers to establish deceptive websites that mimic legitimacy for malicious purposes.

Pre-Conditions:

- The malware is operational and executing within a target system.
- The ability to establish a TCP/IP connection with the C2 server.
- Requirements:
- Pre-Conditions:
- The malware possesses the necessary code to implement web protocols (e.g., HTTP, HTTPS).
- The target system has an active internet connection.
- A functioning network interface on the infected system.

Post-Conditions:

- Potential for further malicious activity, including lateral movement and data destruction.
- Hidden process running with obfuscated name.
- System instability and performance degradation.
- Unusual file access patterns and registry modifications.
- Compromised system with persistent backdoor access.
- Network connections to C2 server logged in system event logs and firewall logs.
- Altered system configuration settings.
- Presence of malicious DLL loaded into memory.
- Modified registry entries related to GoogleUpdate.exe and Goopdate.dll.
- New batch file used for initial setup and persistence.
- Data exfiltration to C2 server.

MITRE Technique

ID: T1071.001

Name: Application layer protocol: web protocols

Description: Adversaries may communicate using application layer protocols associated with web traffic to avoid detection/network filtering by blending in with existing traffic. Commands to the remote system, and often the results of those commands, will be embedded within the protocol traffic between the client and server.

More info: <https://attack.mitre.org/techniques/T1071/001>

Attack Step a15

=====

Name: Fallback Channels as used by the malware

Description: Fallback channels are alternative communication mechanisms employed by malware such as Goofy Guinea Pig to ensure operational continuity in the event of disruptions or blockage of primary Command and Control (C2) infrastructure. Goofy Guinea Pig implements two primary fallback channels: UDP (User Datagram Protocol) and KCP (Keepalive Control Protocol), and direct socket communications. UDP is utilized for data transmission and reception as an alternative to HTTPS communication. KCP, a fast and reliable transport protocol, enhances connection resilience through features such as congestion control and packet loss recovery. As a last resort, Goofy Guinea Pig can establish direct socket connections to its C2 server, bypassing higher-level protocols and relying on raw network communication. The malware's configuration string dictates the fallback channel employed. Upon initial deployment, the malware attempts to connect to its C2 server using HTTPS. In the event of an HTTPS connection failure, the malware consults its configuration string. Based on the configuration, the malware will either switch to UDP and KCP protocols or establish a direct socket connection to the C2 server. The utilization of fallback channels by Goofy Guinea Pig presents challenges for detection and mitigation efforts. Security measures must encompass these alternative communication methods to effectively counter this malware.

Pre-Conditions:

- The malware has established an initial communication channel.
- The malware is running.

Post-Conditions:

- Hidden malicious files (e.g., Goopdate.dll, backdoor binary).
- Log entries indicating suspicious activity and process executions.
- System instability and performance degradation.
- Network traffic to C2 server (static.tcplog.com).
- Modified system files or configurations.
- New service running on the system.
- Deleted temporary files related to the installation and execution of the malware.
- Altered user permissions or access rights.
- Compromised system with persistent backdoor access.
- Potential for further malware infections and attacks.
- Modified Windows registry entries for persistence.
- Data exfiltration to C2 server.

MITRE Technique

ID: T1008

Name: Fallback channels

Description: Adversaries may use fallback or alternate communication channels if the primary channel is compromised or inaccessible in order to maintain reliable command and control and to avoid data transfer thresholds.

More info: <https://attack.mitre.org/techniques/T1008/>

Attack Step a16

=====

Name: Non-Standard Port as used by the malware

Description: Non-standard ports, defined as those exceeding 1023, are frequently employed by malicious actors for several reasons. These include evading detection by security tools that primarily focus on standard ports, circumventing firewalls with rules specific to common ports, and obscuring the malware's origin through the utilization of unique ports. The malware Goofy Guineapig utilizes HTTPS over port 4443 for its communications, deviating from the conventional HTTPS port of 443. This non-standard port selection presents challenges for detection and mitigation strategies. Security tools reliant on standard port monitoring may fail to identify Goofy Guineapig's traffic. Furthermore, firewalls configured to block common ports could potentially permit Goofy Guineapig's communication to proceed undetected. Effective detection and prevention of this malware necessitate the implementation of security measures capable of recognizing and monitoring non-standard ports such as 4443.

Pre-Conditions:

- The malware is configured to use a non-standard port for communication.
- The malware is running.

Post-Conditions:

- Modified system registry entries for persistence.
- Data exfiltration to attacker controlled server.
- Potential for further malicious activity on the compromised system.
- Log files containing suspicious activity.
- Modified user permissions.
- New service running on the system.
- Presence of malicious DLLs in memory and/or file system.
- Compromised system with persistent backdoor access.
- Unusual process creation events.
- Altered or deleted system files.

MITRE Technique

ID: T1571

Name: Non-standard port

Description: Adversaries may communicate using a protocol and port pairing that are typically not associated. For example, HTTPS over port 8088 or port 587 as opposed to the traditional port 443. Adversaries may make changes to the standard port used by a protocol to bypass filtering or muddle analysis/parsing of network data.

More info: <https://attack.mitre.org/techniques/T1571/>